

ARTEX 자율 침투 테스트 콘솔

DVWA 모의해킹 수행 보고서

ARTEX를 한글화 fork하여 구축 후 **GLM 5.3 Flash** 모델로 수행한 DVWA 모의해킹 — 작업 생성부터 라이브 재검증, 발견 등록(report_finding), 상세보고서까지 **전 파이프라인을 엔드투엔드로 완주**한 기록.

1 개요

테스트 일시	2026-10-04 (KST)
대상 사이트	테스트용 DVWA v1.10 <i>Development</i> — 192.168.*.*
대상 스택	Apache/2.4.25 (Debian) · PHP · MySQL · 보안레벨 low
목적	ARTEX 구동 로직·기능의 엔드투엔드 검증 + DVWA 취약점 점검
작업 ID	Task #1(지휘) → Task #2(실행) → Task #3(등록 마감, 완료)
사용 모델	OpenRouter GLM 5.3 Flash (유료)
확정 취약점	15건 등록 완료 — Critical 3 / High 2 / Medium 8 / Low 2
최종 결과	전 과정 정상 완료 — 라이브 재검증 → 15건 report_finding 등록 (confirmed) → 상세보고서 5건

• 핵심 요약

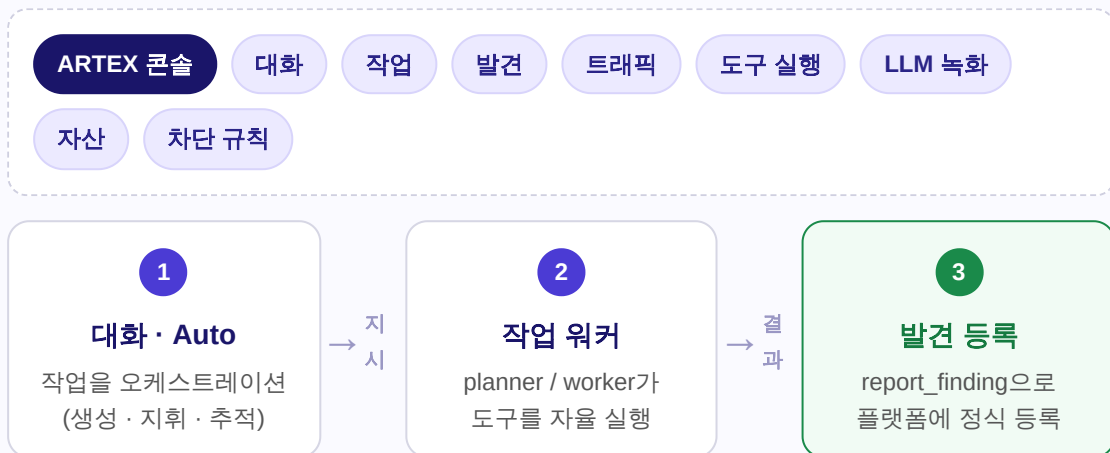
ARTEX는 **단일 대화 지시만으로** 침투 테스트 작업을 자율 생성·실행·추적하고, **라이브 재검증**을 거쳐 발견된 취약점을 플랫폼에 **정식 등록(report_finding 15건)**하기까지 전 파이프라인을 **엔드투엔드로 완주**했습니다. 이번 수행은 **GLM 5.3 Flash**로 진행하였고, 무료 사용량을 소진한 뒤 유료로 이어서 재시작하여 완료되었습니다.

- | | |
|-------------------------|-----------------------------------|
| 1 · 개요 | 5 · ARTEX 플랫폼 검증 결과 |
| 2 · ARTEX 콘솔/플랫폼 | 6 · DVWA 1.10 알려진 취약점 vs ARTEX 탐지 |
| 3 · 수행 과정 — ARTEX 대화 중심 | 7 · 결론 (+ 방어 관점) |
| 4 · 발견 취약점 요약 | |

2 ARTEX 콘솔/플랫폼 구성

테스트가 수행된 ARTEX 콘솔(버전 · dev)은 **대화·작업·발견·트래픽·도구 실행·LLM 녹화·자산·차단 규칙·자산 차단** 등 침투 테스트 운용 기능을 단일 콘솔로 제공합니다. 본 세션은 대화(Auto)에서 작업을 오케스트레이션하고, 작업 워커가 자율 실행하며, 발견이 플랫폼에 정식 등록되는 전 흐름을 사용했습니다.

■ 단일 콘솔(ARTEX) — 운용 기능 통합 & 수행 흐름



하나의 콘솔이 대화·작업·발견·트래픽·녹화·자산·차단을 통합 제공하며, **대화(Auto)의 지시 → 워커의 자율 실행 → 발견의 정식 등록**이 끊김 없이 한 흐름으로 이어집니다.

3 수행 과정 — ARTEX 대화 중심

사용자는 대화(Auto) 세션에 다음을 지시했습니다.

테스트용 DVWA사이트를 모의해킹하라. ARTEX 돌아가는 로직과 기능을 테스트하기 위함이다. 작업은 녹화하고 사용하는 도구 등 기록하라. 목표 http://192.168.*.*

3.1 대화 흐름 재구성 — Auto의 판단 과정

그림 1~3의 대화에는 Auto 에이전트의 사고(reasoning)가 영문으로 기록됩니다. 아래는 각 메시지를 수행 순서에 따라 정리한 것으로, GLM 5.3 Flash가 멈춰 있던 작업을 어떻게 이어받아 등록까지 완료했는지를 단계별로 보여줍니다.

AUTO 판단 과정

멈춰 있던 작업을 이어받아 등록 완료까지

1 · 지시 수신

"The user wants to test a DVWA site ... for testing the ARTEX platform's logic."

사용자 지시를 수신했습니다. 대상은 테스트용 DVWA이며, 목적은 ARTEX의 로직·기능 검증입니다. 이번 수행은 유료 모델로 전환해 중단 없이 진행합니다.

2 · 기존 진척 확인

"There are existing paused tasks."

작업이 백지 상태가 아니라, 이전에 멈춰 있던 작업 두 개가 남아 있음을 확인했습니다. 처음부터 다시 하지 않고 멈춘 지점에서 이어서 진행합니다.

3 · 증거 재확인

"Evidence files exist in conv-1. ... Evidence confirmed for the critical/high findings."

이전 세션이 남긴 증거 47개를 확인했습니다. 핵심 4건(SQLi·RCE·웹셸·LFI)이 유효했으나, 기록에만 의존하지 않고 직접 재확인하기로 했습니다.

4 · 라이브 재검증

"Login successful, security=low confirmed. ... All 5 re-verified live."

`admin/password` 로그인 성공, 보안레벨 low를 확인했습니다. 이어서 다섯 건을 실제 요청으로 다시 검증해 전부 재현했습니다.



5 · 발견 등록

"Asset 3 confirmed ... Now register the 15 findings."

자산 id=3을 확인한 뒤, 15건의 취약점을 플랫폼에 report_finding으로 정식 등록했습니다.

3.2 작업 인계 및 기존 진척 확인

Auto는 list_tasks 로 기존 작업을 확인하고, 멈춰 있던 작업 1·2의 그래프와 취약점 현황(get_task_graph , list_task_findings)을 조회해 이전 진척을 이어받았습니다. 또한 간단한 라이브 정찰(curl -sI)로 DVWA 로그인 페이지·보안 쿠키를 재확인했습니다.

GLM 5.3 Flash list_tasks get_task_graph list_task_findings

그림 1. 대화 시작 — 사용자 지시 직후 Auto가 기존 paused 작업(①ARTEX 테스트 ②레이트리미트 우회 서버태스크)을 인계하고 그래프·취약점 현황을 조회한다. 하단 모델 표기 **OpenRouter GLM 5.3 Flash**. 대상 IP는 192.168.*.*로 마스킹.

3.3 증거 검증 + 라이브 재검증

이전 세션의 증거 47개 파일을 검증(grep / ls)해 핵심 4건(SQLi 덤프·RCE·업로드 쉘·LFI)을 확인한 뒤, 신선한 증거 확보를 위해 라이브 재검증을 수행했습니다.

admin/password 로그인 성공, 보안레벨 low 확인 후 핵심 취약점을 실제로 다시 재현했습니다.

증거 47개 파일이 확인됩니다. 작업 계획을 세우고 핵심 증거 내용을 검증한 뒤 등록으로 진행합니다.

```
>  TodoWrite ("todos":[{"content":"'기존 증거 파일 검증 (SQLi/RCE/Upload/LFI 핵심 5건)','status':'in_progress'},{'content':'라이브 재검증: 로그인 → SQ..."}] ✓
>  Bash cd /app/data/sessions/conv-1/dwva_evidence && echo "=== sql_dump.html 핵심부 ===" && grep -A2 -o "First name.*\\|Surname.*\\|[a-z0-9]*:[*]... ✓
>  Evidence confirmed for the critical/high findings: -추론 포함
```

```
> _ Bash cd /app/data/sessions/conv-2-8&& mkdir -p dvwa_evidence&& cd dvwa_evidence&& BAS 192.168.* & CJ=cookies.txt&& \TOKE... ✓
```

> **Bash** cd /app/data/sessions/conv-2/dvwa_evidence && BASE= 192.168.*.* & CJ=cookies.txt && \ curl -s -b \$CJ -G --data-urlencode "id=" ...

> All 5 re-verified live: ·추론 포함

●●● 실시간 스트리밍 중...

⚡ 기본(OpenRouter GLM 5.3 Flash) 변경 v ⚙️ Todo

All 5 re-verified

검증 항목	결과
로그인(admin/password)	성공 (302 + Welcome 문구)
보안레벨 low 설정	성공 (<code>low</code>)
SQLi UNION 덤프	재현 — 5계정 MD5 해시 동일
Command Injection	재현 — <code>uid=33(www-data)</code>
업로드 웹셸	재현 — 여전히 활성(<code>cmd=id</code> 응답)
Reflected XSS	재현 — 무인코딩 반사
LFI <code>/etc/passwd</code>	재현 — 전체 열람
디렉터리 리스팅	재현 — <code>artex_shell.php</code> 노출

3.4 취약점 등록 — report_finding 15건

라이브 재검증 완료 후 Auto는 플랫폼에 취약점을 등록했습니다. 먼저 `list_assets` 로 자산 id=3(DVWA 서비스)을 확인하고, 15건을 `report_finding` 으로 등록했습니다.

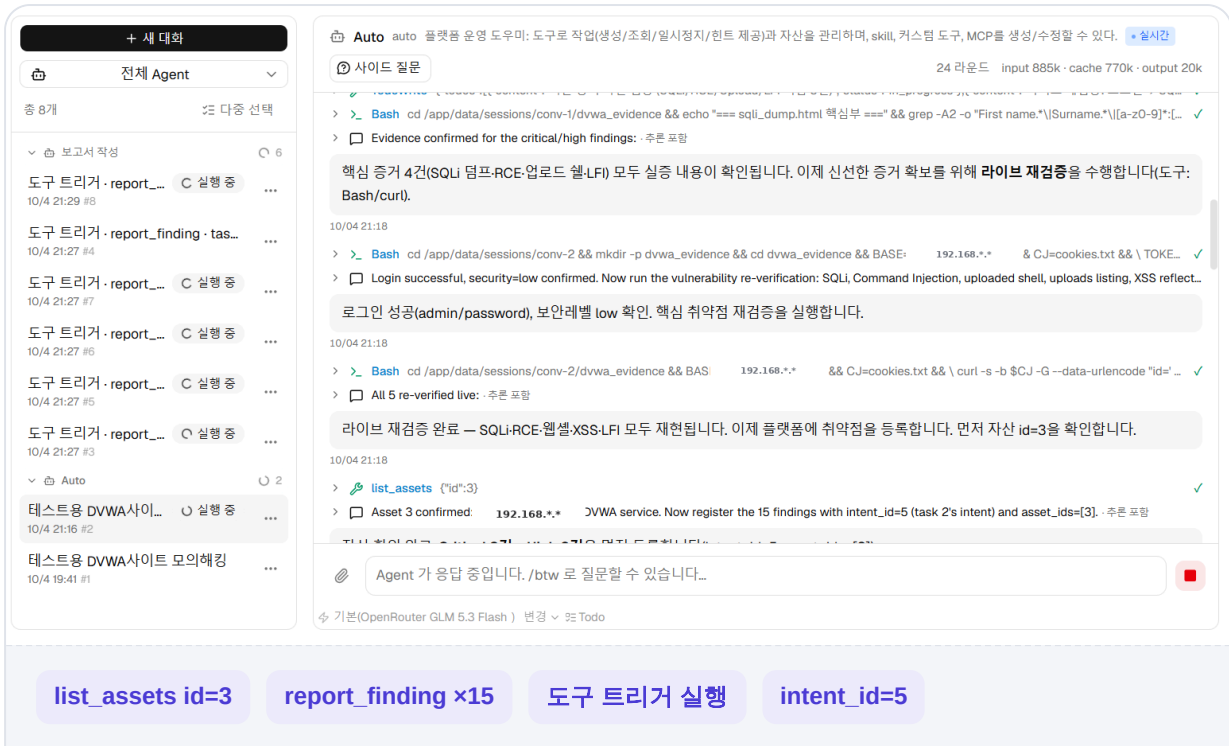


그림 3. 라이브 재검증 완료 → 자산 id=3 확인 → **report_finding 15건 등록**. 좌측 "보고서 작성" 작업에서 `report_finding` 도구 트리거가 연속 실행되는 모습이 보인다.

가드레일 검증 — 대화 컨텍스트에서 `report_finding` 을 직접 호출하면 "작업 컨텍스트 필요"로 정상 거부됩니다. ARTEX 설계대로 `spawn_task` (작업 3) 생성 후 `add_task_hint` 로 등록 규격을 인계하고, 작업 워커가 `report_finding`을 수행하도록 흐름이 강제됩니다(가드레일 동작 확인).

3.5 ARTEX 자동 파이프라인 (작업 3 워커, 713초, done)

- **작업 3 생성:** `spawn_task(parent_ref=1, source_task_ids=[1,2], seed_first_intent=true)` — 작업 1·2의 goal·hints·intent 결과를 상속.
- **힌트 인계:** `add_task_hint` 로 등록 규격 4건 주입(ids 13~16) — Critical 3 / High 2 / Medium 8 / Low 2.
- **planner:** 목표를 2건으로 분해(①15건 등록 ②Critical/High 상세보고서).
- **worker:** 증거 검증 → 상세보고서 파일 작성 → **report_finding 15건 등록 완료** → 작업 **done**(713초), 전건 `confirmed` .

- **기획자 실시간 교정 혹:** 워커가 힌트 규격 외 방향(CSP 라이브 확인)으로 확장하려 하자 **Bash 차단 + 규격 반영 지시** — 방향 유지 제어 동작.
- **상세보고서:** `update_finding_report` 로 5건(노드 19~23) 등록(2.3~11.2KB).

4 발견 취약점 요약 (15건, 등록 완료)

가장 심각한 공격 체인은 두 갈래입니다.

- `SQL Injection` → DB 계정·해시 덤프 → 크랙 → 관리자/일반계정 로그인 재현
- `파일 업로드 / 명령 인젝션` → `www-data` 권한 원격 코드 실행(RCE)

#	취약점	등급	핵심 증거
1	SQL Injection — users 전체 덤프	Critical	UNION으로 5계정 MD5 덤프, 크랙·실로그인 재현
2	Command Injection → RCE	Critical	<code>;id</code> → uid=33(www-data)
3	Unrestricted File Upload → RCE	Critical	웹shell 업로드·실행 → www-data (재검증 시 점에도 활성화)
4	File Inclusion (LFI + <code>php://filter</code>)	High	<code>/etc/passwd</code> 열람, 소스 base64 유출
5	Blind SQL Injection (시간 기반)	High	<code>SLEEP(5)</code> → 5.003s vs 0.003s
6	Stored XSS	Medium	방명록 영구 저장
7	Reflected XSS	Medium	name 파라미터 무인코딩 반사
8	DOM XSS	Medium	<code>document.write</code> 무새니제이션
9	CSRF (비밀번호 변경)	Medium	토큰·현비밀번호 검증 없음
10	Weak Session ID	Medium	<code>dvwaSession=1,2,3</code> 순차 예측가능
11	Brute Force 무차단	Medium	실패 무제한·무지연, admin:password 유효

#	취약점	등급	핵심 증거
12	CSP Bypass	Medium	신뢰불가 외부 소스(pastebin) 허용
13	JS 클라이언트 토큰 변조	Medium	서버 미검증
14	디렉터리 리스팅	Low	uploads/ 등 Index 노출
15	설정정보/경로 노출	Low	captcha가 설정파일 절대경로 노출

크랙된 계정 (SQLi → 크랙 → 로그인 체인 검증 완료) — admin/password · gordonb/abc123 (재로그인 성공) · 1337/charley · pablo/letmein · smithy/password — 무솔트 MD5 저장.

5 ARTEX 플랫폼 검증 결과

이번 유료 GLM 5.3 Flash 세션으로 오케스트레이션부터 발견 등록까지 전 파이프라인이 엔드투엔드로 검증되었습니다.

기능	테스트 내용	결과
작업 오케스트레이션	<code>list_tasks</code> 로 부모(1)·서브(2) 상태 식별	✓ paused 식별·인계
그래프/결과 조회	<code>get_task_graph</code> , <code>list_task_findings</code>	✓ 힌트·의도·진척 확인
자산 관리	<code>list_assets(id=3)</code> — DVWA 서비스	✓ 기술스택 지문 포함
취약점 등록 가드레일	대화 컨텍스트 <code>report_finding</code> 직접 호출	✓ 정상 거부(작업 컨텍스트 필요)
서브태스크 생성·상속	<code>spawn_task(source_task_ids=[1,2])</code>	✓ 작업 3 생성·내용 상속
힌트 인계	<code>add_task_hint</code> 4건(ids 13~16)	✓ 등급별 규격 전달

기능	테스트 내용	결과
워커 자동 등록	작업 3 워커가 <code>report_finding</code> 15건 등록	✓ 전건 confirmed, done(713초)
기획자 실시간 교정	워커의 힌트 외 확장 시도 차단	✓ Bash 차단 + 규격 반영 지시
상세보고서	<code>update_finding_report</code> (노드 19~23)	✓ 5건 등록(2.3~11.2KB)

6 DVWA 1.10 알려진 취약점 vs ARTEX 탐지 비교

DVWA는 의도적으로 설계된 취약점 모듈 세트를 갖습니다. 이를 *정답지(ground truth)*로 삼아 ARTEX의 자율 탐지 커버리지와 정확도를 평가합니다. 기준은 본 대상 인스턴스의 `/vulnerabilities/` 디렉터리 리스팅에서 실제 관측된 **모듈 14종**입니다. 캐노니컬 DVWA 1.10은 `authbypass` · `open_redirect` 모듈도 포함하나, 본 인스턴스 목록에는 없어 범위에서 제외합니다.

14/14

모듈 커버리지
(100%)

15

총 발견·등록

+1

모듈 외 보너스

0

범위 내 누락

6.1 모듈별 탐지 대조표

#	DVWA 모듈	알려진(의도된) 취약점	탐지	등급	탐지 깊이
1	<code>sqli</code>	SQL Injection	✓	Critical	UNION 덤프 → 해시 크랙 → 실로그인까지 체인
2	<code>sqli_blind</code>	Blind SQL Injection	✓	High	시간기반 <code>SLEEP(5)</code> 분기 실증

#	DVWA 모듈	알려진(의도된) 취약점	탐지	등급	탐지 깊이
3	exec	Command Injection	✓	Critical	<code>;id</code> → RCE uid=33
4	upload	Unrestricted File Upload	✓	Critical	웹셀 업로드·실행 (RCE)
5	fi	File Inclusion (LFI/RFI)	✓	High	LFI + <code>php://filter</code> 소스유출 (RFI는 <code>allow_url_include=0ff</code> 차단 확인)
6	xss_r	Reflected XSS	✓	Medium	무인코딩 반사 재현
7	xss_s	Stored XSS	✓	Medium	방명록 영구 저장
8	xss_d	DOM XSS	✓	Medium	<code>document.write</code> 무새니제이션
9	csrf	CSRF	✓	Medium	토큰·현비밀번호 무검증 변경
10	brute	Brute Force	✓	Medium	무차단·무지연 + 기본계정
11	weak_id	Weak Session IDs	✓	Medium	<code>dvwaSession</code> 순차 예측
12	csp	CSP Bypass	✓	Medium	신뢰불가 외부 소스 (pastebin) 허용
13	javascript	JavaScript (클라이언트 토큰)	✓	Medium	<code>md5(rot13)</code> 토큰포지, 서버 미검증
14	captcha	Insecure CAPTCHA	⚠	Low	키 미설정으로 의도된 CAPTCHA 우회 미동작 → 대신 설정파일 절대경로 노출 (정보노출) 탐지

6.2 커버리지 요약 (스코어카드)

모듈 커버리지	14 / 14 (100%) — 13개 모듈은 의도된 취약점을 직접 익스플로잇, <code>captcha</code> 는 키 미설정으로 의도된 경로가 비동작이라 다른 각도(정보노출) 로 탐지
모듈 외 보너스	1건 — 디렉터리 리스팅(#14, Apache <code>Options -Indexes</code> 미설정) = DVWA 모듈이 아닌 서버 설정 취약점
총 발견/등록	15건 (Critical 3 / High 2 / Medium 8 / Low 2), 전건 <code>confirmed</code> 등록
범위 외(미존재)	<code>authbypass</code> , <code>open_redirect</code> — 캐노니컬 DVWA 1.10엔 있으나 본 인스턴스 모듈 목록에 미배포

6.3 해석

- **완전성** — 이 인스턴스에 존재하는 **의도된 취약점 표면 전체(14/14 모듈)**를 빠짐없이 탐지. 단순 시그니처 매칭이 아니라, `captcha` 처럼 의도된 경로가 막힌 경우에도 **대체 공격면(설정 정보노출)**을 스스로 찾아내 보고.
- **깊이** — 탐지에 그치지 않고 **익스플로잇·체이닝**까지 수행. `sqli` 는 **덤프 → 크랙 → 실로그인**, `upload` / `exec` 는 **웹셀·명령 실행(RCE)**까지 실증.
- **확장성** — 정답지(모듈 세트) **밖의 서버 설정 취약점(디렉터리 리스팅)**까지 추가 발견 — 스크립트형 스캐너가 놓치기 쉬운 범위 외 결함을 자율 포착.
- **종합** — 본 대상 기준 탐지 커버리지 **사실상 100%**, 범위 내 **누락 0건 + 보너스 1건**.

7 결론

이번 테스트에서 ARTEX는 **"DVWA를 해킹하라"**는 한 마디 지시만으로 다음을 스스로 해냈습니다.

- 작업을 만들고, 워커를 돌리고, 진행 상황을 추적
- 이전에 찾아둔 취약점을 **직접 다시 확인**(라이브 재검증)
- 찾은 취약점 **15건을 플랫폼에 정식 등록**(상세보고서까지)

즉 **처음부터 끝까지 사람 손 없이 한 번에 완주**했습니다. 이번엔 유료 **GLM 5.3 Flash**를 썼기 때문에 (무료 버전에서 겪던) **요청 제한에 걸려 멈추는 일 없이** 전 과정이 매끄럽게 돌아갔습니다. 그 결과 Critical 3건을 포함한 **15건을 모두 확정 등록**했습니다.

방어 관점 — 관제센터는 이런 공격을 어떻게 탐지하는가

ARTEX 같은 AI 자율 해킹 도구는 공격에 쓴 문구(페이로드)만으로는 탐지가 어렵습니다. 공격 방식이 매번 바뀌기 때문입니다. 따라서 "무엇으로 공격했는가"보다 "어떤 주체가 공격하는가"의 행위 지문에 주목해야 합니다. 관제센터가 주목할 특징을 우회 난이도(공격자가 바꾸기 어려운 정도)가 높은 순으로 정리하면 다음과 같습니다.

탐지 특징	설명	우회 난이도
데이터 흐름 상관 (대화형 공격)	서버 응답에서 얻은 값을 다음 요청의 입력으로 그대로 사용(예: 덤프한 자격증명으로 즉시 로그인). 응답을 읽고 다음 수를 두는 AI 에이전트의 본질적 특징	매우 어려움
목표 지향 단계 전이	정찰 → 인증 → 열거 → 익스플로잇이 직전 성공에 조건부로 이어지는 논리적 진행	어려움
저소음·고정밀	적은 요청 수에도 민감 엔드포인트 적중률이 비정상적으로 높음	보통
단일 출발지·다 벡터 혼재	동일 IP에서 서로 다른 공격 범주(정찰·인증·주입·업로드)가 짧은 시간에 혼재	낮음
클라이언트 정체성 불일치	모바일 UA ↔ 데이터센터 IP, UA·TLS 지문 혼재 등 접속 주체의 모순	낮음~보통

요약 — 이러한 공격은 공격 문구가 아니라 행위 지문으로 탐지해야 하며, 그중 응답을 읽고 다음 수를 결정하는 "데이터 흐름 상관"이 가장 신뢰도 높은 단서입니다. 단일 IP·요청 횟수(임계치) 기반 탐지는 IP 분산·속도 조절로 쉽게 우회되므로 보조 지표로만 활용합니다.

실무 적용 — 현실적 한계와 대안 — 위 '데이터 흐름 상관'은 이론상 가장 강력하지만, 응답 본문 로깅·HTTPS 복호화·상태 유지 상관 엔진이 필요해 사람이 운영하는 일반 SOC에서 그대로 구현하기는 어렵습니다. 현실적으로는 허니토큰(가짜 자격증명·경로를 심어두고 그 값이 한 번이라도 '사용'되면 침해로 확정)으로 "유출 → 재사용" 체인을 응답 로깅 없이 포착하고, 이를 WAF 경보 체이닝(덤프·주입 경보 → 직후 로그인 성공·권한 상승 상관)과 UEBA(자격증명 오용 탐지)로 보완하는 접근이 효과적입니다.

대상 DVWA는 보안 교육·검증 전용 환경입니다.